

2. Análise de maturidade

A InterMed apresenta um organograma ainda tradicional, em que a Segurança está posicionada dentro de IT. A organização não demonstra ainda um modelo maduro de papéis, responsabilidades e autoridades em matéria de segurança, nem uma integração consistente entre o modelo do risco empresarial e a gestão do risco cyber, em contraciclo com o foco de *governance* e *risk management* presente nas boas práticas

Existe um prestador externo para apoio à microinformática e suporte de utilizadores, mas a empresa não tem capacidades consolidadas de gestão de serviço: faltam processos maduros de incident management, problem management, change management, service catalogue, reporting por SLA, escalado funcional e indicadores transversais. Esta fragilidade de operação torna mais difícil obter visibilidade sobre falhas, dependências, degradação de serviços e sinais de incidente, o que enfraquece também as capacidades pedidas pela NIS2 para monitorização, logging, event reporting e incident handling.

A equipa de cibersegurança é reduzida e essencialmente reativa. Não há capacidade interna robusta para arquitetura de segurança, threat detection, governance de terceiros, secure development, testes de segurança ou reporting executivo continuado. Em paralelo, a colaboração entre áreas é limitada, com silos entre IT, operações clínicas, jurídico, compras, risco e negócio, o que dificulta a tomada de decisão coordenada e a institucionalização de uma abordagem “security by design” e “risk by design”.

Assume-se que a InterMed apresenta os seguintes sinais adicionais de baixa maturidade:

- Não existe inventário consolidado e classificado de ativos e serviços críticos.
- O registo de risco corporativo não cobre de forma estruturada os principais cenários cyber.
- Não existe diretório completo e vivo de fornecedores e prestadores de serviços críticos.
- Os contratos com terceiros têm requisitos de segurança pouco uniformes.
- Não existem revisões independentes regulares de segurança nem reporting formal ao órgão de gestão.
- As mudanças tecnológicas urgentes tendem a contornar processos formais.
- A monitorização e o logging são parciais e pouco correlacionados.

- O desenvolvimento aplicacional é maioritariamente orientado por requisitos funcionais e prazos definidos pelas áreas, sem visão de *quick-wins*.

Dados adicionais para análise de maturidade

Considere os seguintes dados como base de análise:

- Existe política corporativa única de segurança aprovada pelo órgão de gestão.
- O comité de risco corporativo não inclui cyber como agenda permanente.
- O board recebe apenas informação reativa quando existe incidente relevante.
- Não há quadro formal de KRIs/KPIs de cyber para gestão.
- Não há processo consistente para aceitação de risco residual.
- Não existe plano anual de revisões independentes de segurança.
- A função de segurança depende de recursos escassos e fortemente operacionais.
- Não existe calendarização formal de exercícios executivos de incidente/crise.

Questões

1. Avalie a maturidade atual de governance & gestão cyber da InterMed numa escala de 1 a 5 e justifique.
2. Identifique as principais lacunas face à NIS2 no domínio de governance, risco e reporting executivo.

Nota: utilize o anexo específico como folha de resposta

3. Comunicação ao *board* e requisitos *governance*

A nova administração da InterMed iniciou um programa de transformação digital com forte pressão sobre crescimento, eficiência e experiência do doente. Entre as prioridades estratégicas estão o reforço dos canais digitais, a modernização dos sistemas de relacionamento com o doente, o aumento da integração entre unidades, a aposta em analytics e a criação de novos serviços digitais. O CEO reconhece, contudo, que a organização pode estar a assumir riscos de execução que não domina totalmente, sobretudo porque a maturidade de governação digital e de cibersegurança ainda é baixa.

No atual organograma, a Segurança da Informação está inserida na área de IT. O risco corporativo não incorpora de forma sistemática a cibersegurança, a articulação entre equipas é fraca e não existe uma linha clara de comunicação executiva sobre risco cyber, terceiros críticos, incidentes, exposição regulatória ou impacto estratégico. O novo CEO quer alterar esta situação e pediu ao responsável de segurança uma visão mais direta, orientada à decisão, sobre o estado da cibersegurança e as prioridades dos próximos 12 meses.

Como parte deste movimento, o CEO decidiu promover um workshop executivo de duas horas com o board alargado, incluindo CEO, CFO, COO, diretor clínico, compras, jurídico/compliance e risco corporativo. O objetivo é alinhar linguagem, clarificar responsabilidades, perceber as implicações práticas da NIS2 e discutir que modelo de *governance* deve suportar a nova estratégia digital. O responsável de segurança vê aqui uma oportunidade para reposicionar a função, sair da lógica puramente técnica e passar a enquadrar a cibersegurança como tema de governação, resiliência e execução estratégica.

Há, no entanto, constrangimentos adicionais que agravam a análise de maturidade. A InterMed não faz reporting regular ao órgão de gestão com formato standardizado; não existem comités formais onde cyber, risco, operações e negócio decidam em conjunto; as revisões independentes de segurança são esporádicas; a gestão de exceções e de risco residual é pouco documentada; e muitas decisões sobre fornecedores, cloud ou novas aplicações são tomadas por projeto, sem uma visão transversal. À luz da NIS2, estas fragilidades mostram insuficiência em áreas como política de segurança, papéis e responsabilidades, framework de risco, compliance monitoring, independent review e reporting ao management body.

Questões

1. Análise a situação específica da *Governance* e os requisitos necessários à luz da NIS2
2. Estructure uma agenda para o workshop executivo.
3. Defina as principais mensagens executivas que o CISO deve levar ao CEO e ao board.
(Cyber SWOT)

Checklist de apoio

- Existe política de segurança aprovada pela gestão?
- Estão definidos papéis, responsabilidades e autoridades?
- O risco cyber integra o ERM?
- Existe reporting regular ao órgão de gestão?
- Há indicadores executivos sobre exposição, capacidade e progresso?
- Existem revisões independentes e compliance monitoring?
- Há processo de aceitação de risco residual?
- Os terceiros críticos entram na visão executiva de risco?
- Existe preparação executiva para incidentes e crises?
- O modelo atual permite escalar a estratégia digital com controlo?

Nota: utilize o anexo específico como folha de resposta